Engineering Specification: Unique IDs & Security Audit Engine

Architecture Brief for Community Platform Infrastructure • Version 1.0

> **Executive Directive:** To mitigate Insecure Direct Object Reference (IDOR) vulnerabilities and establish robust compliance tracking, all application entities must transition from sequential integers to prefixed, time-ordered TypeIDs backed by automated immutable audit logging.

1. System Scope & Entity Taxonomy

Every core resource within the community app must feature a cryptographically unguessable, human-identifiable unique identifier. Standard prefixes must be strictly enforced across all database tables, API routing layers, and frontend payloads.

Entity Name	Prefix	Description & Scope
User Profile	`usr_`	Residents, local business managers, and admin accounts.
Local Business	`biz_`	Verified merchant storefronts and service listings.
News Article	`nws_`	Editorial posts, breaking alerts, and community updates.
Local Event	`evt_`	Town gatherings, council sessions, and public meetings.
Marketplace Listing	`mkt_`	Classified goods, freebies, and user-to-user items.
Audit Log Record	`aud_`	System security events, records modifications, and admin actions.

2. Identifier Generation Standard

Underlying IDs must implement **UUIDv7** specification: combining high-entropy cryptographic randomness with a millisecond-precision timestamp prefix. This ensures chronological database index sorting without sequential disclosure.

3. Database Schema & Migration Requirements

Primary keys must be defined as `VARCHAR(36)` supporting string format entities. Foreign key constraints must strictly enforce matching entity prefix validation at the application migration layer.

```
CREATE TABLE audit_logs (
    audit_id VARCHAR(36) PRIMARY KEY,      -- Format: aud_[uuidv7]
    actor_id VARCHAR(36) NOT NULL,         -- Format: usr_[uuidv7] or 'system'
    action_type VARCHAR(50) NOT NULL,      -- e.g., 'BIZ_APPROVED', 'USER_BAN'
    resource_type VARCHAR(20) NOT NULL,    -- e.g., 'business', 'user', 'news'
    resource_id VARCHAR(36) NOT NULL,      -- Format: biz_[uuidv7]
    ip_address VARCHAR(45),                -- IPv4 or IPv6 tracking
    metadata JSONB,                        -- Before/after diff and request context
    created_at TIMESTAMPTZ DEFAULT NOW() NOT NULL
);
```

4. Database Performance Indexing

To prevent performance degradation during security audits or incident investigations, composite indexes must be deployed for reverse-lookup operations.

```
 -- Reverse lookup: Track all history associated with a target resource
CREATE INDEX idx_audit_resource ON audit_logs (resource_id, created_at DESC);

-- Actor accountability: Track all actions executed by a specific administrator/user
CREATE INDEX idx_audit_actor ON audit_logs (actor_id, created_at DESC);

-- Incident categorization: Slice audit streams by action type over time
CREATE INDEX idx_audit_action_time ON audit_logs (action_type, created_at DESC);
```

5. Implementation Mandate for Developers

- **Immutability:** The `audit_logs` table must restrict write access to the internal service layer only. No application update or delete endpoints may alter historical audit records.
- **Middleware Binding:** All mutating API operations (POST, PUT, DELETE, PATCH) must automatically dispatch an event to the `AuditLoggerService` capturing caller IP, actor ID, and state deltas.
- **API Exposure:** Public URLs must route exclusively via prefixed IDs (e.g., `/api/v1/businesses/biz_01h...`) rather than auto-incremented database integers.